Have you found any high-severity vulnerabilities? Discussing supply chain security and related risk management is out of scope for this book. I want to show you how to perform and automate vulnerability scanning for application artifacts, but I'll leave it up to you to follow up on the scan results. I can't stress enough how important it is to define a security strategy in your organization and automate, as much as possible, its compliance verification throughout the whole value stream.

In this section, I mentioned a few essential aspects you should consider when building production-grade container images, but there's even more to cover. Is there another way to build production-grade container images? The following section introduces a different option.

DOCKERFILES OR BUILDPACKS

Dockerfiles are very powerful, and they give you complete fine-grained control over the result. However, they require extra care and maintenance and can lead to several challenges in your value stream.

As a developer, you might not want to deal with all the performance and security concerns we've discussed. You might prefer to focus on the application code instead. After all, one reason to move to the cloud is to deliver value to customers faster. Adding the Dockerfile step and considering all those issues might not be for you.

As an operator, it might be challenging to control and secure the supply chain within the organization when container images are built from a Dockerfile. It's pretty common to invest some time in scripting the *perfect* Dockerfile and to copy that into multiple repositories for different applications. But it's hard to keep all teams on the same page, verify